IMSJ

RC5

INFORME DE SEGURIDAD

Análisis dinámico de seguridad (DAST)

Portal Vial y Educación Vial IMSJ

Fecha de ejecución	20 de octubre de 2026
Herramientas	OWASP ZAP 2.17.0 (baseline) y Nmap 7.98
Objetivo	Portal público local en http://host.docker.internal:8000/
Entorno	Docker local, Apache httpd 2.4.68, puerto 8000/tcp
Identificador de versión	Commit 5f15b3b

El escaneo no produjo fallos de política ni alertas de severidad alta. Sí identificó una superficie de endurecimiento pendiente: cabeceras de seguridad, carga de recursos externos sin integridad y una ruta posible de envío de credenciales por URL. La recomendación es corregir los puntos prioritarios y repetir el escaneo antes de publicar el portal.

33	14	0	53
URLs exploradas	reglas con alerta	fallos del baseline	controles aprobados

Equipo RC5

Clasificación interna | Entregable técnico

01 | LECTURA EJECUTIVA

Resumen y decisión

El resultado es aceptable para un entorno local de desarrollo, pero no constituye una aprobación de seguridad para producción. ZAP ejecutó un baseline pasivo y no autenticado: observó respuestas y configuración expuesta, pero no intentó explotar la aplicación ni recorrió el panel administrativo con sesión.

Señal	Resultado	Lectura correcta
Baseline ZAP	0 FAIL · 14 WARN · 53 PASS	No hubo reglas configuradas como fallo; permanecen advertencias que requieren triage.
Reporte JSON	17 entradas · 67 instancias	Las 14 reglas se desagregan por variantes (COEP/COOP/CORP y caché).
Severidad ZAP	3 reglas medias · 7 bajas · 4 informativas	No se registraron reglas altas; la prioridad final también considera contexto de negocio.
Nmap	8000/tcp abierto · Apache 2.4.68	La exposición coincide con el servicio esperado, pero revela versión del servidor.

Decisión recomendada

Estado	Condición
PUBLICACIÓN CONDICIONADA	Resolver las prioridades P1, repetir ZAP y conservar el reporte de revalidación.
Uso local/demostración	Permitido dentro del alcance autorizado y sin datos reales.
Producción institucional	No recomendada con este informe como única evidencia; faltan HTTPS, prueba autenticada, API y validación de correcciones.

Prioridades de cierre

- P1. Evitar cualquier fallback GET de los formularios de acceso y confirmar que las credenciales nunca aparecen en la URL.
- P1. Definir una CSP compatible con el portal, protección anti-clickjacking y nosniff en respuestas HTML/estáticas.
- P1. Hospedar localmente Lucide o fijar su versión con Subresource Integrity y crossorigin.
- P2. Ocultar versiones, completar cabeceras cross-origin y validar la política de caché por tipo de recurso.
- P2. Repetir el análisis con sesión, Client Spider y pruebas específicas de API en un entorno autorizado.

Alcance, método y límites

Alcance autorizado

Elemento	Detalle
Objetivo principal	http://host.docker.internal:8000/frontend-publico/
Origen adicional	http://host.docker.internal:8000/ (redirección al portal público)
Contenido explorado	33 URLs informadas por la ejecución del baseline.
Servicio revisado	127.0.0.1:8000 desde contenedor Nmap con red del host.
Fuera de alcance efectivo	Panel IMSJ autenticado, acciones con sesión, cobertura completa de API, fuerza bruta, lógica de negocio, base de datos y pruebas activas.

Procedimiento reproducible

1. Se creó el directorio de evidencia y se ejecutó ZAP Baseline dentro del contenedor oficial estable.
2. ZAP utilizó Automation Framework, spider de hasta un minuto y escaneo pasivo; guardó HTML y JSON.
3. Se ejecutó Nmap TCP Connect con detección de versión únicamente sobre el puerto 8000 local.

```
docker run --rm -v "${PWD}/informes-dast:/zap/wrk:rw" --add-host=host.docker.internal:host-gateway
ghcr.io/zaproxy/zaproxy:stable zap-baseline.py -t http://host.docker.internal:8000/frontend-publico/ -r
zap-report.html -J zap-report.json -I

docker run --rm --network host instrumentisto/nmap -sT -sV -p 8000 127.0.0.1
```

Límites de interpretación

- El parámetro -I evita tratar las advertencias como error de salida; no convierte los WARN en controles aprobados.
- El baseline es principalmente pasivo. No acredita ausencia de SQLi, XSS, fallas de autorización, CSRF ni vulnerabilidades de lógica.
- La aplicación fue analizada por HTTP local. TLS, HSTS y configuración del dominio real deben comprobarse en el entorno de publicación.
- La alerta “Modern Web Application” sugiere usar Client Spider para descubrir rutas dependientes de JavaScript.

Panorama de alertas

La tabla resume las 17 entradas del JSON. La prioridad propuesta no replica mecánicamente la severidad de ZAP: combina exposición, facilidad de corrección y efecto sobre credenciales o ejecución en navegador.

ID	Hallazgo ZAP	Riesgo	Inst.	Prioridad
10038	Content Security Policy (CSP) Header Not Set	Medio	5	P1
10020	Missing Anti-clickjacking Header	Medio	5	P1
90003	Sub Resource Integrity Attribute Missing	Medio	5	P1
10024	Sensitive Information in URL	Info	3	P1 contextual
10021	X-Content-Type-Options Header Missing	Bajo	5	P1
10036	Server version disclosure	Bajo	5	P2
10037	X-Powered-By disclosure	Bajo	2	P2
10017	Cross-Domain JavaScript Source File Inclusion	Bajo	5	P2
90004	COEP Header Missing or Invalid	Bajo	3	P2
90004	COOP Header Missing or Invalid	Bajo	3	P2
90004	CORP Header Missing or Invalid	Bajo	5	P2
10063	Permissions Policy Header Not Set	Bajo	5	P2
10044	Big Redirect Detected	Bajo	2	P3
10027	Suspicious Comments	Info	2	P3 / falso positivo
10109	Modern Web Application	Info	3	Cobertura
10049	Non-Storable Content	Info	4	Revisar
10049	Storable and Cacheable Content	Info	5	Revisar

Distribución por regla única

Nivel ZAP	Reglas	Instancias	Interpretación
Medio	3	15	Controles del navegador ausentes o incompletos.
Bajo	7	35	Endurecimiento, aislamiento de origen y divulgación de información.
Informativo	4	17	Cobertura, caché y señales que necesitan validación manual.

Controles del navegador

DAST-01	Content Security Policy no definida	MEDIO
Observación	ZAP detectó ausencia de CSP en cinco respuestas, incluidas la raíz, el portal, estudio, login y noticias.	
Impacto	Sin una política explícita, un XSS o recurso manipulado dispone de mayor libertad para cargar scripts, estilos o destinos externos.	
Acción recomendada	Definir CSP inicialmente en modo Report-Only, observar incompatibilidades y luego aplicar una política restrictiva. Evitar unsafe-inline cuando sea posible y limitar script-src a orígenes necesarios.	
Criterio de cierre	Las páginas HTML responden con una CSP efectiva, la interfaz conserva su funcionalidad y ZAP ya no informa 10038.	

DAST-02	Protección anti-clickjacking ausente	MEDIO
Observación	Cinco páginas no enviaron X-Frame-Options ni una directiva CSP frame-ancestors equivalente.	
Impacto	Un sitio externo podría embeber la interfaz y engañar a una persona para interactuar con controles superpuestos.	
Acción recomendada	Preferir CSP frame-ancestors 'none' o una lista institucional mínima. Agregar X-Frame-Options: DENY como compatibilidad si el portal no necesita ser embebido.	
Criterio de cierre	Las respuestas HTML bloquean el embeber no autorizado y ZAP ya no informa 10020.	

DAST-03	Recursos de terceros sin verificación de integridad	MEDIO
Observación	ZAP registró cinco instancias y el código carga Lucide desde unpkg. El análisis SAST existente ya había señalado el mismo patrón en ocho páginas.	
Impacto	Una alteración del recurso o de su cadena de entrega podría ejecutar JavaScript bajo el origen del portal.	
Acción recomendada	Opción preferida: alojar una copia aprobada dentro del proyecto. Alternativa: fijar versión, hash SRI y atributo crossorigin, verificando que el proveedor entregue contenido inmutable.	
Criterio de cierre	No quedan scripts externos sin integridad; ZAP 90003 y la regla SAST correspondiente desaparecen sin pérdida de iconos.	

Credenciales y cabeceras

DAST-04	Posible exposición de credenciales en URL	ALTA CONTEXTUAL
Observación	ZAP observó tres URL de login con parámetros cedula, password y password_confirm. Los formularios HTML no declaran método; JavaScript cancela el envío y usa POST, pero un fallo, bloqueo o carga incompleta del script deja disponible el comportamiento GET por defecto.	
Impacto	Las URL pueden persistir en historial, registros, herramientas de monitoreo o cabeceras Referer. Aunque los valores ZAP eran sintéticos, el patrón es relevante para credenciales reales.	
Acción recomendada	Declarar explícitamente method='post' en los tres formularios y una acción segura o fallback que no exponga secretos. Mantener el envío API por POST y probar el comportamiento con JavaScript deshabilitado o fallido.	
Criterio de cierre	Ninguna navegación, log ni captura contiene contraseñas en query string; ZAP 10024 desaparece y las pruebas negativas confirman que GET no procesa credenciales.	

DAST-05	X-Content-Type-Options ausente en contenido web	BAJO
Observación	Cinco respuestas públicas, incluido CSS e imagen, no devolvieron X-Content-Type-Options: nosniff. La API sí define esta cabecera en sus respuestas JSON y archivos.	
Impacto	Algunos navegadores pueden interpretar un contenido con un tipo distinto al declarado, ampliando el efecto de cargas o respuestas mal configuradas.	
Acción recomendada	Configurar la cabecera en Apache para portal y panel, sin limitarla a las respuestas del backend PHP. Confirmar tipos MIME correctos.	
Criterio de cierre	Todas las respuestas estáticas y dinámicas incluyen nosniff y ZAP ya no informa 10021.	

DAST-06	Versiones y tecnología expuestas	BAJO
Observación	Nmap identificó Apache httpd 2.4.68 y ZAP detectó Server y X-Powered-By en varias respuestas, incluidas páginas 404.	
Impacto	La información reduce el trabajo de reconocimiento de un atacante y facilita asociar vulnerabilidades conocidas a versiones visibles.	
Acción recomendada	Aplicar ServerTokens Prod, ServerSignature Off y expose_php=Off. Mantener parches del contenedor y verificar también respuestas de error.	
Criterio de cierre	Las respuestas no revelan versión ni X-Powered-By; Nmap identifica el servicio sin una versión innecesariamente precisa.	

Observaciones agrupadas

Grupo	Evidencia	Riesgo	Tratamiento recomendado
Aislamiento cross-origin	COEP 3, COOP 3 y CORP 5 instancias	Bajo	Definir políticas solo después de inventariar recursos, ventanas y documentos compartidos; probar compatibilidad del portal.
Permissions-Policy	5 respuestas sin cabecera	Bajo	Deshabilitar capacidades del navegador no utilizadas (por ejemplo cámara, micrófono y geolocalización) y habilitar únicamente las justificadas.
JavaScript de otro dominio	5 páginas con fuente cross-domain	Bajo	Resolver junto con DAST-03: recurso local o proveedor fijado, SRI y CSP.
Redirecciones grandes	2 respuestas 302	Bajo	Conservar redirecciones simples y sin cuerpo sensible. Validar que Location no dependa de entrada externa.
Caché	4 no almacenables y 5 almacenables	Info	Distinguir HTML público, archivos estáticos y respuestas con identidad. Aplicar no-store a datos sensibles y versionado/max-age a recursos públicos.
Comentarios sospechosos	2 coincidencias en api.js	Info	Triage manual: la evidencia corresponde a una frase en español que contiene la secuencia “Retira”; parece falso positivo de la regla TODO. Conservar como revisado.
Aplicación moderna	3 instancias	Info	No es una vulnerabilidad. Usar Client Spider para mejorar la cobertura de rutas controladas por JavaScript.

Relación con la configuración observada

- backend/apache.conf limita índices y publica únicamente las rutas previstas, pero no define todavía el conjunto de cabeceras del portal.
- backend/core/Response.php ya envía no-store y nosniff para JSON; la corrección debe extenderse a HTML, CSS, JavaScript, imágenes y errores de Apache.
- frontend-publico/js/login.js cancela el submit y frontend-publico/js/api.js usa POST; el HTML debe conservar una defensa segura incluso si ese JavaScript no se ejecuta.

Exposición de red

Activo	Resultado Nmap	Evaluación
127.0.0.1:8000/tcp	open · http · Apache httpd 2.4.68	Servicio esperado en el entorno local. No se evaluaron otros puertos ni exposición externa.

07 | PLAN DE ACCIÓN

Corrección y revalidación

Orden	Acción	Responsable sugerido	Evidencia de cierre
1 · P1	Asegurar POST/fallback de los formularios y eliminar credenciales de URL.	Frontend + backend	Prueba con JS activo/inactivo; logs e historial sin secretos; ZAP 10024 ausente.
2 · P1	Aplicar CSP, anti-clickjacking y nosniff en Apache.	Infraestructura	Cabeceras verificadas en 200, 302, 404 y API; interfaz sin regresiones.
3 · P1	Eliminar dependencia remota o agregar SRI/crossorigin.	Frontend	ZAP/SAST limpios para integridad y carga cross-domain.
4 · P2	Ocultar versiones y X-Powered-By.	Infraestructura	ZAP 10036/10037 ausentes; Nmap sin versión detallada.
5 · P2	Definir Permissions-Policy, políticas cross-origin y caché.	Arquitectura + infraestructura	Matriz de compatibilidad y nueva ejecución sin alertas no aceptadas.
6 · Cobertura	Ejecutar Client Spider y sesión de prueba sobre panel/API.	Seguridad / QA	Reporte autenticado, rutas cubiertas, usuarios de prueba y límites documentados.

Guion mínimo de revalidación

- Ejecutar la misma línea base contra el mismo corte de código y conservar HTML, JSON, consola y fecha.
- Comparar por identificador de regla: nuevo, persistente, corregido o aceptado con justificación.
- Comprobar manualmente cabeceras en 200, redirecciones y errores; revisar que CSP no rompa iconos, navegación ni formularios.
- Confirmar que login y registro no generan query strings con claves, aun si JavaScript no carga.
- Añadir escaneo autenticado de panel/API con cuentas de rol acotado y datos sintéticos.

Criterio de aceptación propuesto

Condición	Umbral
Hallazgos P1	0 abiertos
Alertas medias nuevas	0, salvo aceptación explícita documentada
Credenciales en URL	0 instancias y prueba negativa aprobada
Regresiones funcionales	0 en navegación, login, registro e iconos
Trazabilidad	Commit, fecha, comandos, reportes y capturas conservados

08 | EVIDENCIA

Ejecución del baseline ZAP

La captura registra la creación del directorio, descarga de la imagen oficial estable, inicio del Automation Framework, total de 33 URLs y controles PASS iniciales.

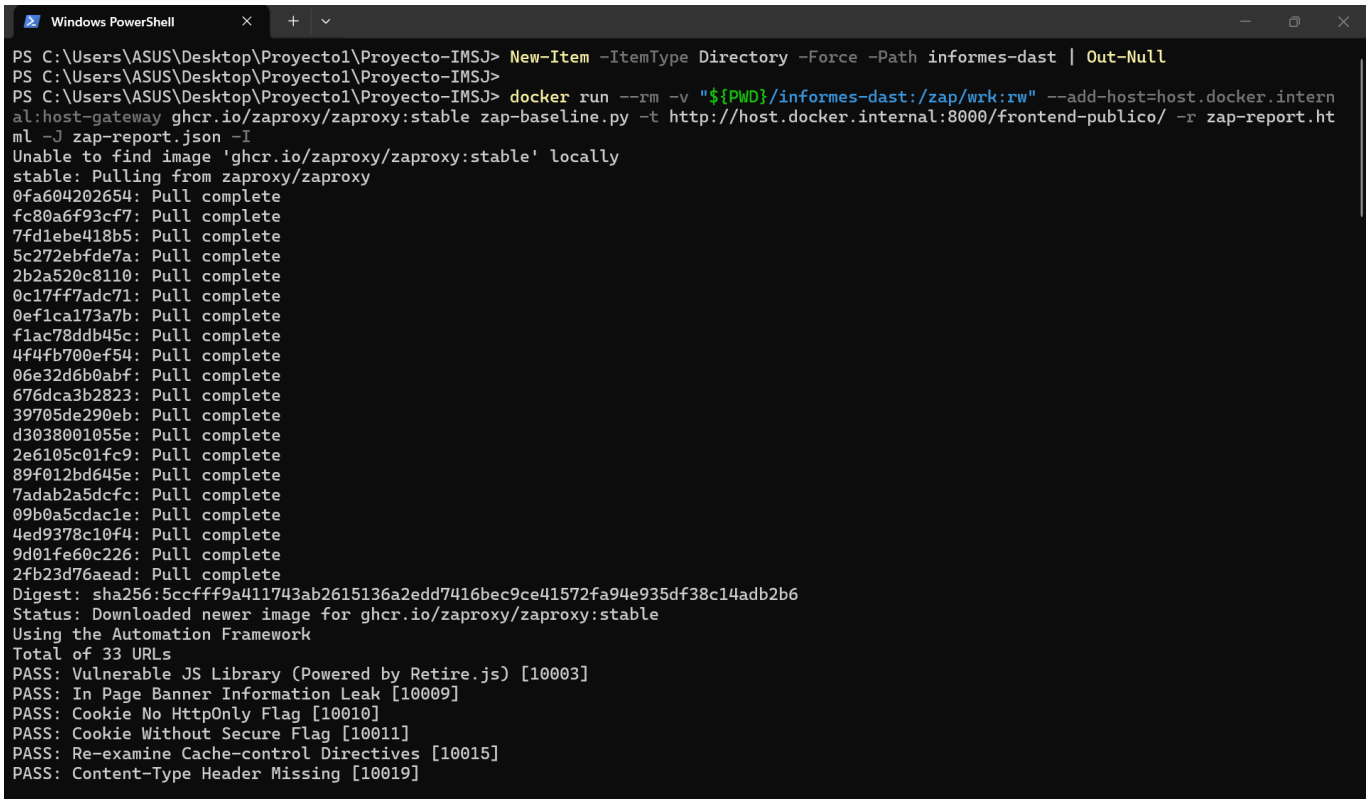


Figura 1. Inicio y progreso del escaneo ZAP Baseline, 20/10/2026.

Dato verificable	Valor
Imagen	Captura de pantalla 2026-10-20 170835.png
Comando	zap-baseline.py con salida HTML y JSON
Objetivo	http://host.docker.internal:8000/frontend-publico/
Contexto	Contenedor con host.docker.internal resuelto mediante host-gateway

09 | EVIDENCIA

Alertas y resumen del baseline

La salida final muestra ejemplos de políticas ausentes y el resumen consolidado: 0 FAIL, 14 WARN y 53 PASS. Ese resultado se corresponde con las 14 reglas únicas registradas en el JSON.

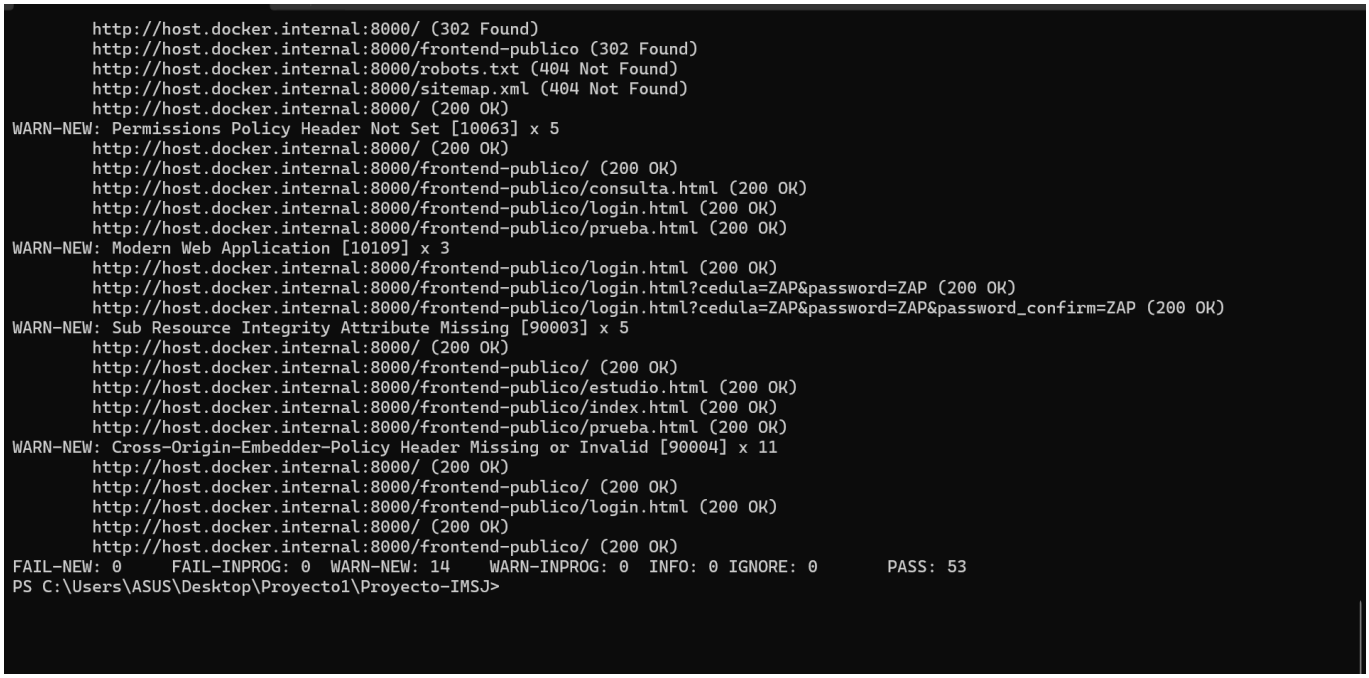


Figura 2. Tramo final del baseline y resumen de resultados, 20/10/2026.

Indicador	Resultado
FAIL-NEW / FAIL-INPROG	0 / 0
WARN-NEW / WARN-INPROG	14 / 0
INFO / IGNORE / PASS	0 / 0 / 53
Lectura	El baseline terminó sin fallos de política, pero requiere triage y revalidación de advertencias.

10 | EVIDENCIA

Reconocimiento Nmap y procedencia

Nmap confirmó que el host local estaba activo y que el puerto previsto publicaba HTTP mediante Apache. El análisis se limitó expresamente a 8000/tcp.

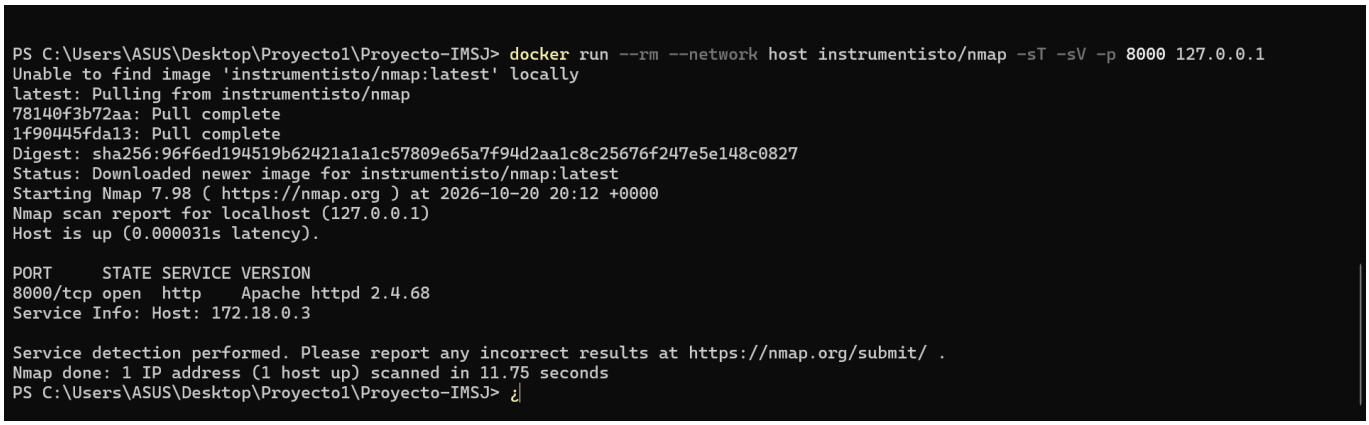


Figura 3. Detección de servicio en 127.0.0.1:8000, 20/10/2026.

Campo	Resultado
Host	localhost (127.0.0.1), activo
Puerto	8000/tcp open
Servicio	http
Versión detectada	Apache httpd 2.4.68
Duración informada	11,75 segundos

Integridad de los artefactos fuente

Archivo	SHA-256
zap-report.json	2F7FE678713736987E4A62582A2FC79A2F193EF0262FD6250580D03CDB9EBFF4
zap-report.html	7BD21A6FE2B7E45D8FCC427CEF4775D4D8604C65DBA92BC3F860668B9BB9FD16
nmap-report.txt	3CE3FF369040DD970C539DD70D7369BE4979B08F930938D99A784FDE8DBA8F96

11 | CIERRE

Conclusiones y referencias

Conclusión

El DAST confirmó una superficie local coherente con el diseño esperado y no registró fallos de política ni hallazgos ZAP de severidad alta. Sin embargo, evidenció controles de navegador y endurecimiento que deben completarse. La condición más delicada es la posibilidad de que los formularios recurran a GET si el JavaScript no intercepta el envío; su corrección es pequeña y reduce un riesgo desproporcionado sobre credenciales.

El informe no afirma que la aplicación esté libre de vulnerabilidades. Para cerrar el ciclo se necesita aplicar las medidas P1, repetir el baseline y ampliar la cobertura a rutas autenticadas, panel, API y navegación dinámica. La publicación institucional también requiere HTTPS y la configuración real del dominio.

Referencias técnicas

Referencia	Uso en este informe
OWASP ZAP 2.17.0 · reporte tradicional JSON/HTML	Fuente primaria de alertas, instancias, severidad y confianza.
ZAP Baseline Scan	Interpretación del escaneo pasivo, WARN/FAIL y límites de cobertura.
OWASP Secure Headers Project	CSP, anti-clickjacking, nosniff, políticas cross-origin y permissions policy.
MDN Web Docs · Subresource Integrity	Tratamiento de recursos externos con integrity y crossorigin.
Nmap 7.98	Identificación del puerto y versión del servicio local.
Código del proyecto · commit 5f15b3b	Validación contextual de formularios, cliente API y configuración Apache.

Artefactos conservados

- informes-dast/zap-report.html — reporte navegable generado por ZAP.
- informes-dast/zap-report.json — fuente estructurada utilizada para el triage.
- informes-dast/nmap-report.txt — salida textual del reconocimiento de servicio.
- Capturas de ejecución incorporadas en las páginas 9 a 11 de este informe.

FIN DEL INFORME

Revalidación posterior a correcciones

OWASP ZAP Baseline y Nmap se ejecutaron nuevamente el 21/10/2026 contra el contenedor reconstruido desde el árbol de trabajo del proyecto. La verificación previa confirmó CSP, anti-clickjacking, nosniff, políticas cross-origin, Permissions-Policy y caché diferenciada.

14	4	0	63
reglas con alerta iniciales	reglas con alerta posteriores	fallos de política	controles aprobados

Controles corregidos

Hallazgo inicial	Tratamiento comprobado	Estado
CSP y anti-clickjacking	Content-Security-Policy con frame-ancestors y X-Frame-Options: DENY.	Cerrado
Script externo sin integridad	Lucide fue sustituido por iconos SVG locales.	Cerrado
Credenciales en URL	Los tres formularios declaran POST; no aparecieron query strings con claves.	Cerrado
nosniff y políticas del navegador	Se añadieron X-Content-Type-Options, COOP, COEP, CORP y Permissions-Policy.	Cerrado
Divulgación tecnológica	X-Powered-By se elimina y Nmap informa Apache httpd sin versión.	Cerrado
JavaScript de terceros	No quedan scripts externos en el portal revisado.	Cerrado

Decisión posterior

Los hallazgos prioritarios P1 del baseline inicial quedaron cerrados. El resultado posterior fue 0 FAIL, 4 WARN y 63 PASS. Las advertencias restantes se sometieron a triage y no muestran una vía de explotación confirmada en el alcance pasivo y no autenticado ejecutado.

Triage de advertencias restantes

El JSON posterior contiene 5 entradas, 12 instancias y cuatro identificadores de regla únicos. La diferencia se debe a que ZAP representa dos decisiones de caché bajo el mismo identificador 10049.

Regla	Evidencia posterior	Clasificación del equipo
10202 - Ausencia de token anti-CSRF	3 formularios de login/registro.	No aplicable al flujo revisado: la API no autentica con cookies, exige JSON y usa token Bearer en sessionStorage. Los formularios son una defensa POST si falla JavaScript.
10027 - Comentarios sospechosos	2 instancias en api.js; evidencia: 'etira del navegador...'.	Falso positivo lingüístico por la palabra 'Retira'; no contiene secretos, tareas pendientes ni información operativa.
10109 - Aplicación web moderna	1 señal por scripts del login.	Informativa. Justifica Client Spider para ampliar cobertura; no requiere corrección.
10049 - Caché	5 respuestas no almacenables y 1 CSS cacheable.	Comportamiento esperado: HTML y errores usan no-store; CSS público usa max-age=3600 y no contiene datos personales.

Nmap posterior

Objetivo	Resultado	Lectura
host.docker.internal:8000	open - http - Apache httpd	Único puerto incluido en el alcance; la versión 2.4.68/2.4.69 ya no se divulga.

Límite que permanece

Esta revalidación confirma el baseline público y el reconocimiento del puerto 8000. No sustituye una prueba autenticada del panel, Client Spider, auditoría específica de la API ni pruebas activas de lógica de negocio. Esas actividades deben mantenerse separadas y ejecutarse solo con cuentas y datos de prueba.

Evidencia posterior

Figura 4. Resumen final de OWASP ZAP: 0 FAIL, 4 WARN y 63 PASS.

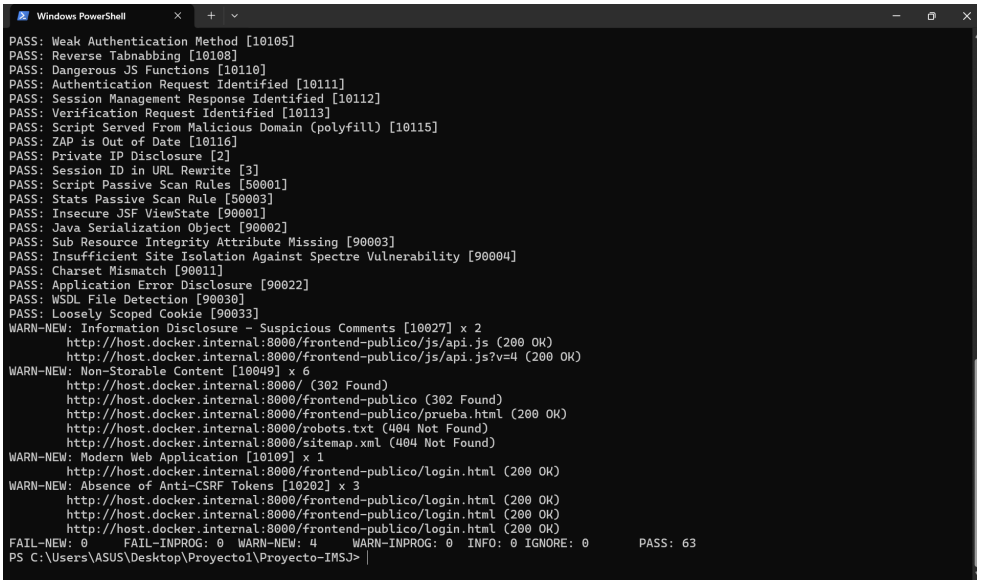
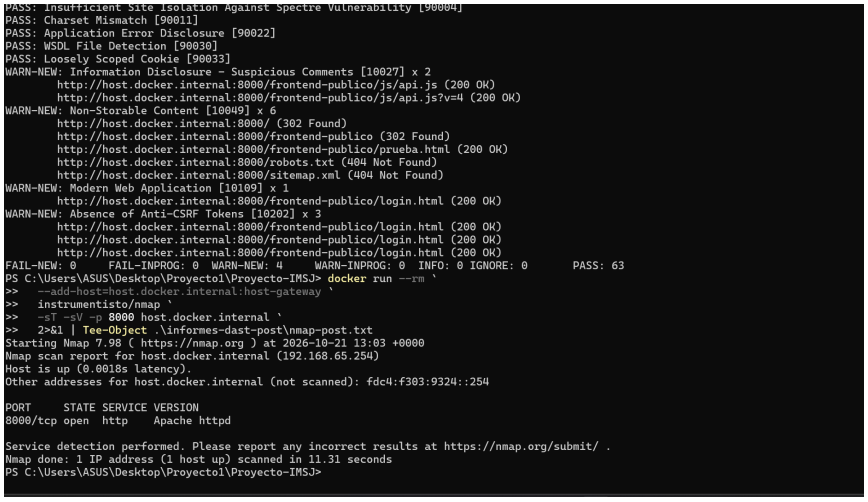


Figura 5. Nmap confirma el puerto 8000 y oculta la versión exacta de Apache.



Integridad de artefactos posteriores

Artefacto	SHA-256
zap-report-post.json	316C4AE7D043A11A9F6BC21A3FC4A3A12AFA12E7F54FB13E23DFA16BDCD54F30
zap-report-post.html	4FA956EEB6DB097F18BBEBB6FF6350B2ECC757A87D3DBCAD392A0C1D4B750E31
zap-post-terminal.txt	9831E979C6DDDDB785AB92357717E87FF56F2074397E8A7F270818CCA1764FB5
nmap-post.txt	11CEC12C79378F827037A061A73CFDAABE7BF80008E77A33A982C2C64B41D7F1